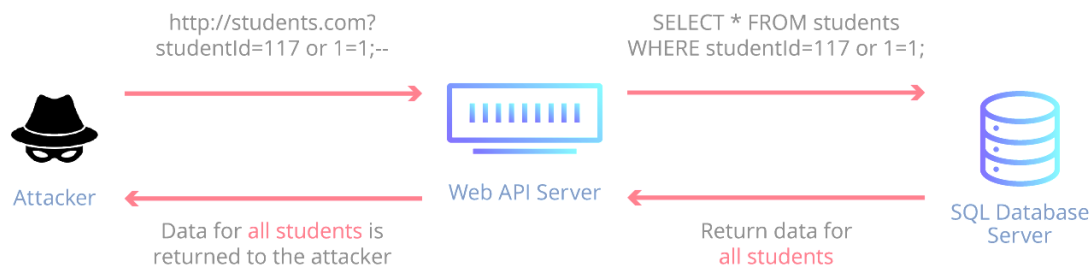


SQL Injection:

- o SQL injection is a code injection technique that might destroy your database.
- o SQL injection is one of the most common web hacking techniques to gain access.
- o SQL injection is placement of malicious code in SQL statements, via web page input.
- o SQL Injection is injection attack makes possible to execute malicious SQL statements.
- o Attackers can use SQL Injection vulnerabilities to bypass application security measures.
- o SQL Injection (SQLi) also used to add, modify, and delete records in the database.
- o SQL injection attack exploits vulnerable cloud-based applications allow pass SQL commands.
- o SQL injection is a code injection technique that might destroy your database.
- o SQL injection is one of the most common web hacking techniques and methods.
- o SQL injection is the placement of malicious code in SQL statements, via web page input.
- o SQL injection is web security vulnerability that allows attacker to interfere with queries.
- o SQL Injection is one of the many web attack mechanisms used by hackers to steal data.
- o SQL injection uses malicious code to manipulate database into revealing information.
- o SQL injection is application security weakness that allows attackers to control database.

SQL Injection

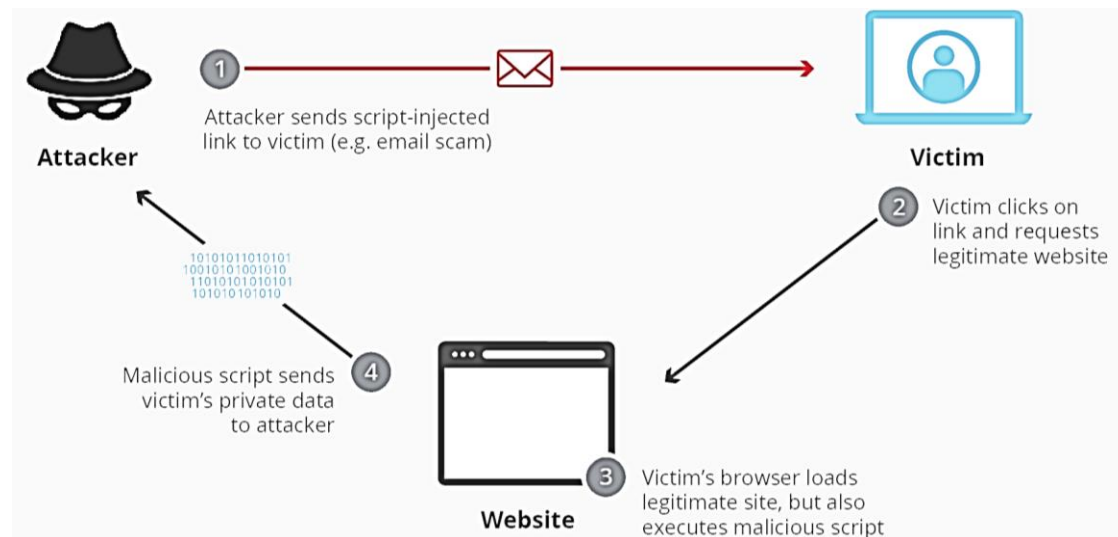


Damn Vulnerable Web App (DVWA)

' OR '1'='1

Cross Site Scripting:

- o XSS is term, which stand for Cross-Site Scripting Errors, are a type of coding error.
- o Where a malicious party can trigger execution of software from their browser.
- o Cross-site scripting is a type of security vulnerability found in web applications.
- o XSS enables attackers to inject client-side scripts into web pages viewed by other users.
- o Common purpose of XSS attack is to collect cookie data such as session IDs or login info.
- o XSS used to steal cookies exploited to gain access as authenticated user to a cloud-based.
- o Three major categories are Reflected XSS, Stored(Persistent) XSS, and DOM-Based XSS.
- o XSS is used to capture cookie/session information for future Man-in-Middle attacks.
- o Every time a user logs in their cookie information could be sent to a remote location.



`<script>alert(document.cookie)</script>`

Vulnerability: Stored Cross Site Scripting (XSS)

The image shows a screenshot of a web application interface with a sidebar menu on the left and a main content area on the right. The sidebar menu includes options like Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), and XSS (Stored). The XSS (Stored) option is highlighted in green. The main content area displays a form with fields for Name and Message. A message box is overlaid on the form, displaying the alert message: "The page at http://192.168.114.234 says: security=low; PHPSESSID=049hdv9f170a5n10fp7fhhs0j5". The message box also includes an OK button.

Damn Vulnerable Web App (DVWA)

Phishing:

- o Phishing is a type of social engineering attack often used to steal user data or info.
- o Phishing is social engineering attack to steal login credentials & credit card numbers.
- o Phishing is method of trying to gather personal info using deceptive e-mails & websites.
- o Phishing is a cyber-attack that uses disguised email as a weapon to steal user data or info.
- o Phishing is a cyber-attack that uses disguised email as a weapon to obtain sensitive data.
- o Phishing attacks attempt to gain sensitive, confidential information such as usernames etc.
- o Phishing attacks involved tricking a victim into taking some action that benefits the attacker.
- o Phishing can be conducted via a text message, social media, or by phone mainly for email.
- o Phishing is a type of spam mail and is an attempt to obtain confidential information.
- o Phishing attack happens when someone tries to trick you into sharing personal info online.



Known as SET, the Social Engineering Toolkit has been in wide use since its creation. Social-Engineer Toolkit is an open-source penetration testing framework designed for social engineering. SET has many custom attack vectors that allow you to make a believable attack quickly.

```
Select from the menu:

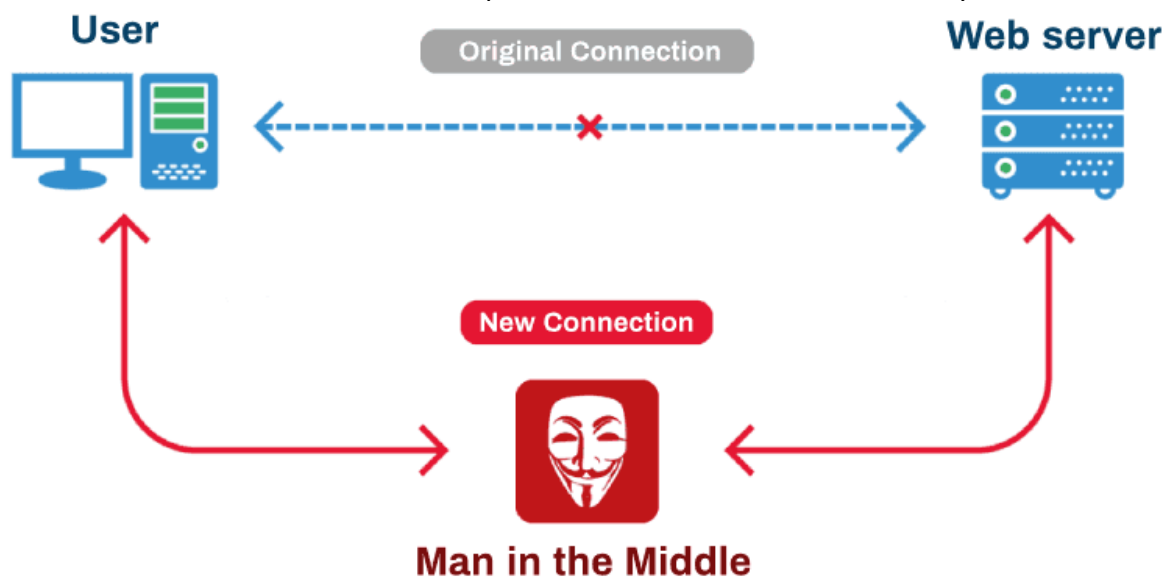
1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set>
```

Man-In-The-Middle:

- o MITM (Man in The Middle) means man in the middle of your conversation.
- o In a Man-in-The-Middle attack, attackers place themselves between two devices.
- o MITM attack to intercept or modify communications between the two devices.
- o MITM cyberattacks allow attackers to secretly intercept communications.
- o MITM attack happens when hacker inserts themselves between a user & apps.
- o Attackers have many different reasons and methods for using a MITM attack.
- o MITM is used to steal something, like credit card numbers or user login credentials.
- o MITM attacks involve interception of communication between two digital systems.
- o A MITM attack is when an attacker intercepts communications between two parties.
- o The man-in-the middle attack intercepts a communication between two systems.



Ettercap:

Ettercap is a comprehensive suite for man in the middle attacks. It features sniffing of live connections, content filtering on the fly and many other interesting tricks.

Select the sniff mode in Main Menu **Sniff > Unified Sniffing**

Select the Interface **Eth0** and Click **OK**

Scan for host inside your subnet **Hosts > Scan for Hosts**

See the **MAC & IP addresses** of the hosts inside your subnet. **Hosts > Hosts list**

Select the machines to poison **Host List**

ARP poison Highlight the line containing and click on the "**target 1**" button.

Highlight the line containing and click on the "**target 2**" button.

Check your targets in Main Menu Click on **Targets > Current targets**

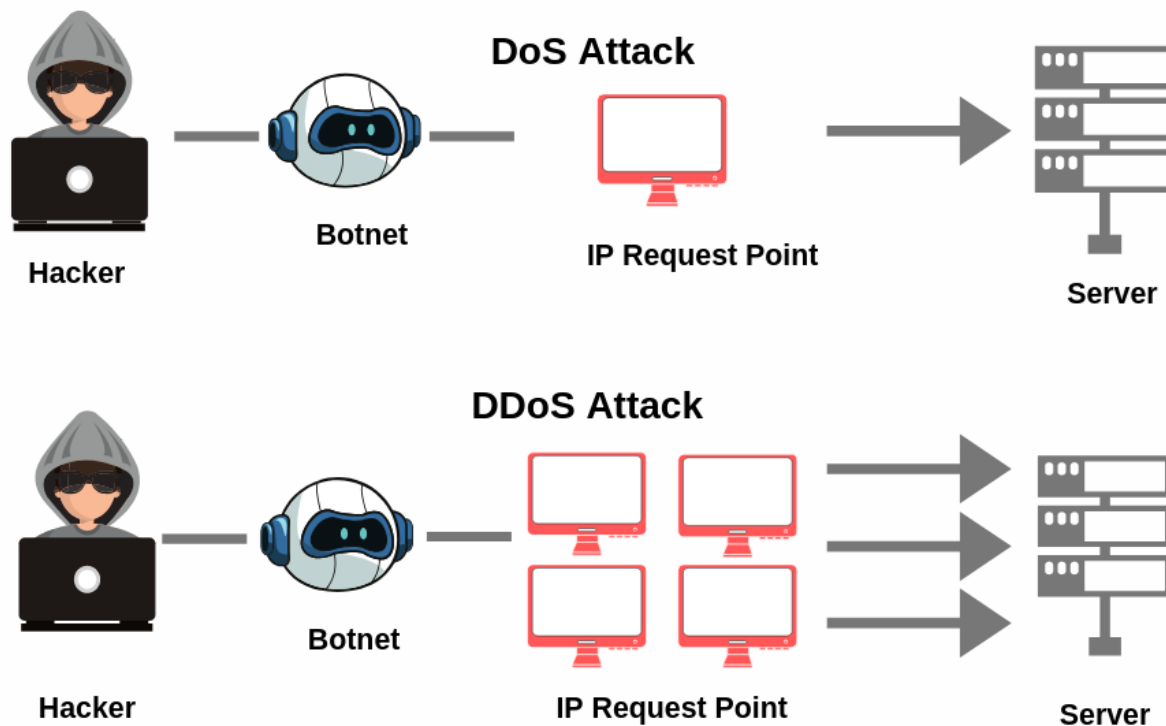
Start the sniffer in Main Menu **Start > Start sniffing**

Start the ARP poisoning in Main Menu click on **Mitm > ARP poisoning**

DoS (Denial of Service) Attack:

- o DoS Attack is a type of attack to network server with large number of service requests.
- o DoS Attack can cause server to crash the server & legitimate users are denied the service.
- o DDoS stand for (Distributed Denial of Service) an Attack, which is one type of DoS attack.
- o DDoS originating from many attacking computers from different geographical regions.
- o Zombies and Botnets are mainly used in DDoS (Distributed Denial of Service) attacks.
- o Both type of attack DoS and DDoS can cause the services to become unavailable to users.
- o Such as Ping of Death, Smurf Attack, TCP SYN , CDP Flood, Buffer Overflow, ICMP Flood.
- o Cloud is more vulnerable to DoS attacks because it is shared by many users & organizations.

DoS vs DDoS Attacks



Ping of Death Using bat Commands and Using Nemesy launch DOS Attack.

CDP Flooding Attacking Using Yersinia.

TCP SYN Flood DOS Attack Using Kali Linux HPING3 `hping3 -S 192.168.169.140 -p 80 --flood`
`hping3 -c 15000 -d 120 -S -w 64 -p 80 --flood --rand-source 1.1.1.1`

- o The Path Traversal attack technique forces access to files, directories, and commands.
- o That potentially reside outside web document root directory, called Directory traversal.
- o This type of security vulnerability allows attackers to gain access to files and directories.
- o The attacker simply sends a file or directory request with the character sequence “../”.
- o Hence the alternative name “dot dot slash attack”, which points to the parent directory.

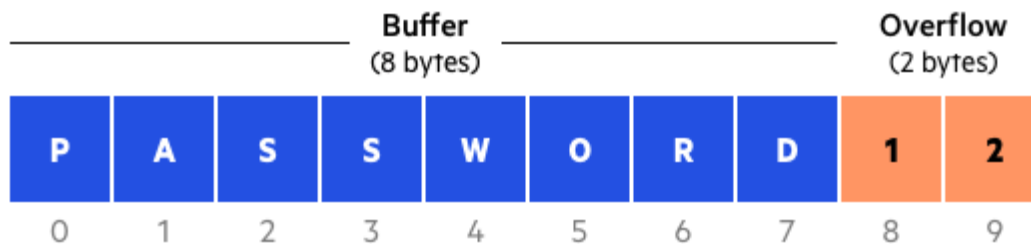


A screenshot of a web browser's address bar. The address bar shows the URL `192.168.114.234/mutillidae/images/`, which is highlighted with a red rectangular box. Above the address bar, a tab is visible with the text "Index of /mutillidae/images".

Name	Last modified	Size	Description
Parent Directory		-	
add-icon-32-32.png	2017-01-07 00:38	1.6K	

Buffer Overflow:

- o A buffer is nothing but a temporary area or temporary memory for data storage.
- o Buffers temporarily hold data while it is being transferred from one location to another.
- o Buffer overflow occurs when volume of data exceeds storage capacity of memory buffer.
- o As result program attempting to write data to buffer overwrites adjacent memory locations.
- o The Attackers exploit buffer overflow issues by overwriting the memory of an application.
- o The Buffer overflows occur when a program tries to write or read more data from buffer.
- o A buffer overflow can give an attacker the access to different parts of the internal memory.
- o Control program execution introduce risks in confidentiality, integrity and the availability.
- o Forms of security vulnerabilities that frequently give potential attacker full control of PC.



OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.6.67 Security Level: 0 (Hosed) Hints: Enabled (1 - Try easier) Not Logged In

Home | Login/Register | Toggle Hints | Show Popup Hints | Toggle Security | Enforce SSL | Reset DB | View Log | View

OWASP 2017 A1 - Injection (SQL) ▶

OWASP 2013 A1 - Injection (Other) ▶ Application Log Injection

OWASP 2010 A2 - Broken Authentication and Session Management ▶ Buffer Overflow ▶ Repeater

OWASP 2007 A3 - Sensitive Data Exposure ▶ Cascading Style Injection

Web Services A4 - XML External Entities ▶ CBC-bit Flipping

HTML 5 A5 - Broken Access Control ▶ Command Injection

Others A6 - Security Misconfiguration ▶ Frame Source Injection

Documentation A7 - Cross Site Scripting (XSS) ▶ HTML Injection (HTMLi)

Resources A8 - Insecure Deserialization ▶ HTMLi via HTTP Headers

 A9 - Using Components with Known Vulnerabilities ▶ HTMLi via DOM Injection

 A10 - Insufficient Logging and Monitoring ▶ HTMLi via Cookie Injection

 ▶ HTTP Parameter Pollution

 ▶ JavaScript Injection

Please enter string to repeat

String to repeat test

Number of times to repeat 2000000

Repeat String ▶